# Privatklinik Annabichl GmbH

Privatklinik in Klagenfurt. Ein Kernbereich: Operationen am Gehirn.

GmbH, KMU, ein Standort
36 Mitarbeitende, 2 Säle, 18 Betten, Ambulanz
Zuweisung durch Neurologen und Unfallchirurgie
Kasse und Wahlarzt

Operiert wird bei Tumoren, Blutungen und Liquorabfluss.
Bilder, Befund und OP-Plan kommen aus dem Haus, nicht von einem zweiten Standort.
Die Navigation im Saal legt das MRT vom Vortag auf den Kopf. Ohne das Bild sieht der Operateur nicht, wo das Instrument zum Tumor steht.

Vision: Sicher operieren, Schmerzen danach im Griff, Bilder und Befunde bleiben im Haus.
Mission: Gehirn-OPs und die kurze stationäre Phase danach.


Bleier, Bugelnig, Lugger, Mele, Schmickl

# Womit die Klinik ihr Geld verdient

| | |
|---|---|
| **Stationäre OPs** | Tagessätze und Eingriffe über ÖGK, SVS und BVAEB. |
| **Wahlarzt-Ambulanz** | Vorstellung vor der OP und Kontrolle danach. Läuft über Zuweiser, nicht über Werbung. |
| **Kein Zusatzgeschäft** | Keine Reha-Abteilung, kein Geräteverkauf. Wer nicht am Gehirn operiert wird, ist nicht unser Patient. |

Was das für die Sicherheit heißt: MRT und OP-Plan sind die Operation. Falscher Patient auf den Bildern heißt falscher Schnitt. Fällt das Bildarchiv oder die Navigation an einem OP-Tag aus, steht der Saal. Deshalb braucht der Saal ein Backup und einen Notbetrieb, nicht nur eine Policy.

# Informationssicherheitsstrategie

Bilder und Befunde sieht nur das Behandlungsteam. OP-Plan und Bildseite stimmen mit der Akte überein. Ein Ausfall stoppt nicht mitten in der Liste, ohne dass der Saal es merkt.

Rahmen: DSGVO Art. 9 (Gesundheitsdaten), ärztliche Verschwiegenheit, Krankengeschichte nach KAKuG § 10, NISG 2026 (unter der Größenschwelle, nur als Orientierung).

| | |
|---|---|
| **Vertraulichkeit** | Neurologische Diagnosen und Bilddaten. Ein Leak ist hier ein Existenzproblem, die Zuweiser hören auf. |
| **Integrität** | Seite, Schicht und Name auf dem Bild müssen zur Akte passen. Sonst wird am falschen Ort operiert. |
| **Verfügbarkeit** | Bildarchiv und Navigation in den OP-Zeiten. Website und Gäste-WLAN dürfen ausfallen, der Saal nicht. |

Risikobereitschaft niedrig bei Bildern, Akte und Saal. Mittel bei Website und Gäste-WLAN.
Geschäftsführung trägt die Strategie, QM macht sie nebenher. Owner: OP, Befundung, Verwaltung. Kein CISO in Vollzeit.
Das KGI „meldepflichtiger Vorfall“ meint die Meldung nach Art. 33 DSGVO.

# Aktionsplan, erstes Jahr

1 Gap-Analyse gegen den Zielzustand, nicht aus einem Katalog.

2 Policy: Zugriff nur, wer den Patienten behandelt. Keine Befunde in privaten Messengern.

3 Drei Netze: Klinik, Gäste-WLAN, Saal und Bildarchiv.

4 Schulung vor dem ersten Zugriff. Bildarchiv-Betreiber und Navigationshersteller mit Exit.

5 Backup des Bildarchivs, lokale Kopie der Bilder für den OP-Tag, Notbetrieb im Saal einmal jährlich üben.

**KGI** Kein meldepflichtiger Vorfall mit Bildern oder Befunden. Kein Ausfall von Archiv oder Navigation über 1 Stunde an einem OP-Tag, gemessen am Notbetrieb.

**CSF** Owner benannt. Geschult, bevor jemand Bilder sieht. Drei Netze. Backup und lokale OP-Kopie stehen.

**KPI** Zugriffe mit Rolle. Stunden bis ein Konto nach dem Austritt gesperrt ist. Notbetrieb geübt, ja oder nein.